SECURITY EAGLES

CRTP

CERTIFIED RED TEAM PROFESSIONAL

PART II

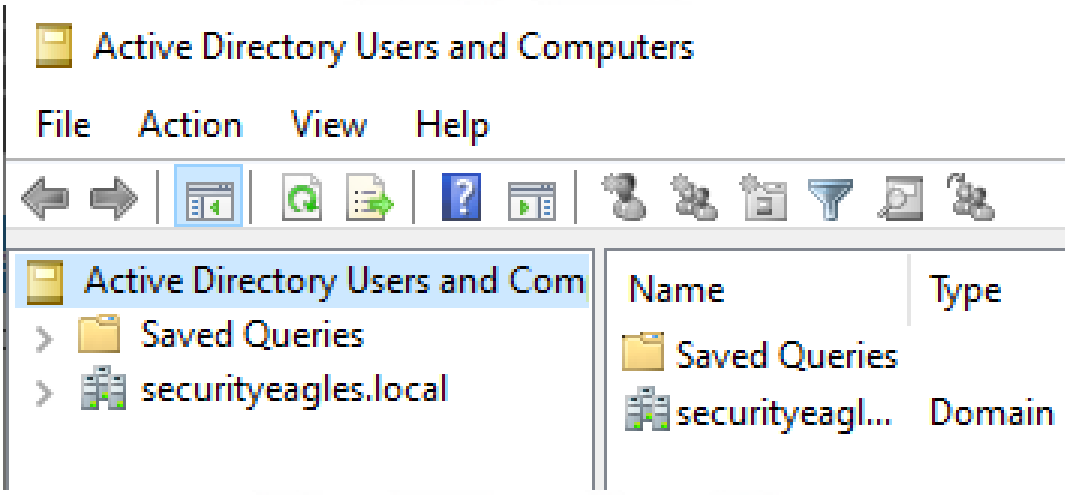
ACTIVE DIRECTORY ENUMERATION

www.securityeagles.com

FROM LEARNERS TO LEADERS

- **Before we start**
  - We will begin with a foundational lab that introduces the core concepts. This lab environment is designed to be scalable and modular, allowing us to continuously expand and add complexity to the exercises as the course progresses and new topics are introduced.
- **Home Lab requirements (What you'll need)**
  - Virtualization Platform (Hypervisor):
    - A stable platform to run your virtual machines, such as VMware Workstation/Fusion or Oracle VirtualBox.
  - Windows Server Virtual Machine (VM):
    - This machine will be configured as your Domain Controller (DC), the primary target for Active Directory attacks
    - Windows Server (2022 or 2025 recommended)
  - Windows Workstation Virtual Machine (VM):
    - his will serve as a target host and a foothold host within the virtual domain, mimicking a typical corporate machine.
    - Windows 10 or Windows 11

- For the domain name we are going to use securityeagles.local to follow along this course

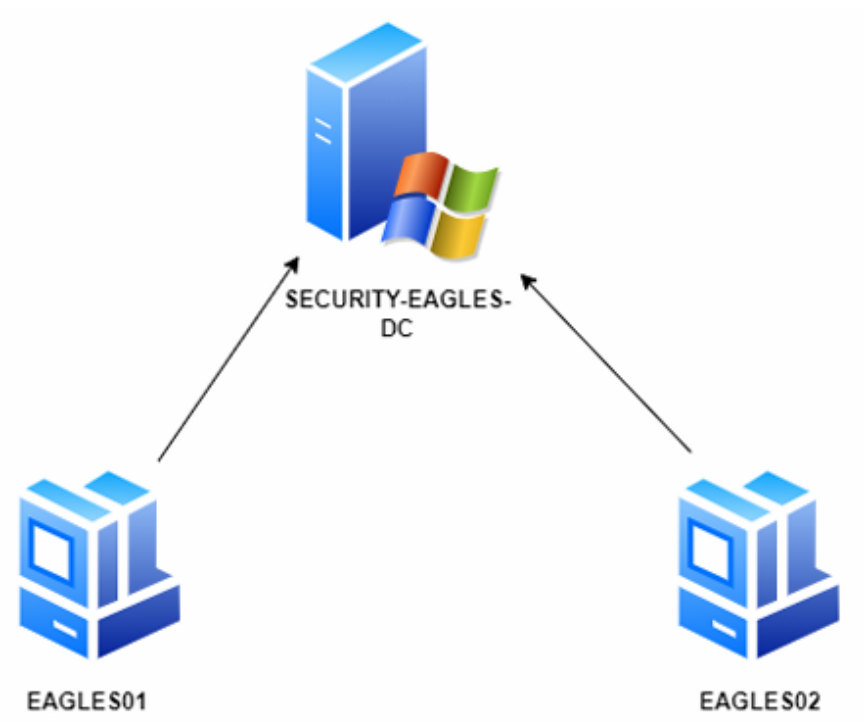


- This will be the hostname for the Domain Controller.

```
C:\Users\Administrator>hostname
SECURITY-EAGLES-DC

C:\Users\Administrator>_
```

- Our lab architecture consists of three machines: the Domain Controller, named SECURITY-EAGLES-DC, and two workstations, EAGLES01 and EAGLES02, all joined to the securityeagles.local domain .



3. ACTIVE DIRECTORY ENUMERATION

- Domain discovery & topology
- Users & groups enumeration
- Computers enumeration
- Forest/intra-forest trust analysis
- GPO discovery & settings audit
- ACL inspection & interesting rights
- Service, SPN & delegation discovery
- Credential sources (configs, secrets)
- Session & logon enumeration
- BloodHound mapping & queries
- Automation & scripting (PowerShell/C#)

1- Domain discovery & topology

- We must first set the PowerShell execution policy to Bypass. This ensures we can successfully execute all necessary scripts and tools throughout the lab without restriction.

```
PS C:\Users\m.dynamo\Downloads> Set-ExecutionPolicy Bypass -Scope CurrentUser

Execution Policy Change
The execution policy helps protect you from scripts that you do not trust. Changing the execution
you to the security risks described in the about_Execution_Policies help topic at
https:/go.microsoft.com/fwlink/?LinkID=135170. Do you want to change the execution policy?
[Y] Yes  [A] Yes to All  [N] No  [L] No to All  [S] Suspend  [?] Help (default is "N"): Y
PS C:\Users\m.dynamo\Downloads>
```

- We will extensively utilize PowerView as the primary tool for Active Directory enumeration.
- We utilize dot sourcing (.) to load the contents of the script directly into the current PowerShell session's memory. This is required to make the script's functions (such as the PowerView cmdlets) immediately available for execution.

```
PS C:\Users\m.dynamo\Downloads> . .\PowerView.ps1
PS C:\Users\m.dynamo\Downloads>
```

- Before we start enumerating the domain we will set the credentials of the current domain user for this session. This setup is necessary for executing PowerView and other authentication-dependent commands.
- As some PowerView commands needs user credentials to be passed as commandline arguments.

```
PS C:\Users\m.dynamo\Downloads> $SecPassword = ConvertTo-SecureString 'GreatADLab123' -AsPlainText -Force
PS C:\Users\m.dynamo\Downloads>
```

- After setting the user's password, our next step is to securely capture these credentials as a PSCredential object for use within the current PowerShell session.
- We will use the command below to create and store the necessary PSCredential object.

```
PS C:\Users\m.dynamo\Downloads> $Cred = New-Object System.Management.Automation.PSCredential('SECURITYEAGLES\m.dynamo', $SecPassword)
PS C:\Users\m.dynamo\Downloads>
```

- Get-Domain retrieves the Active Directory object for the current domain.

```
PS C:\Users\m.dynamo\Downloads> Get-Domain


Forest                  : securityeagles.local
DomainControllers       : {SECURITY-EAGLES-DC.securityeagles.local}
Children                : {}
DomainMode              : Unknown
DomainModeLevel         : 7
Parent                  :
PdcRoleOwner            : SECURITY-EAGLES-DC.securityeagles.local
RidRoleOwner            : SECURITY-EAGLES-DC.securityeagles.local
InfrastructureRoleOwner : SECURITY-EAGLES-DC.securityeagles.local
Name                    : securityeagles.local
```

- To target a specific environment, most commands allow the use of additional parameters, such as specifying the exact domain name.

```
PS C:\Users\m.dynamo\Downloads> Get-Domain -domain securityeagles.local


Forest                  : securityeagles.local
DomainControllers       : {SECURITY-EAGLES-DC.securityeagles.local}
Children                : {}
DomainMode              : Unknown
DomainModeLevel         : 7
Parent                  :
PdcRoleOwner            : SECURITY-EAGLES-DC.securityeagles.local
RidRoleOwner            : SECURITY-EAGLES-DC.securityeagles.local
InfrastructureRoleOwner : SECURITY-EAGLES-DC.securityeagles.local
Name                    : securityeagles.local
```

- Use Get-DomainController to retrieve a list of all Domain Controllers within the current domain/forest.

```
PS C:\Users\m.dynamo\Downloads> Get-DomainController


Forest                     : securityeagles.local
CurrentTime                : 04/11/2025 16:09:20
HighestCommittedUsn        : 32817
OSVersion                  : Windows Server 2022 Standard Evaluation
Roles                      : {SchemaRole, NamingRole, PdcRole, RidRole...}
Domain                     : securityeagles.local
IPAddress                  : 192.168.100.34
SiteName                   : Default-First-Site-Name
SyncFromAllServersCallback :
InboundConnections         : {}
OutboundConnections        : {}
Name                       : SECURITY-EAGLES-DC.securityeagles.local
Partitions                 : {DC=securityeagles,DC=local, CN=Configuration,DC=securityeagles,DC=local,
                             CN=Schema,CN=Configuration,DC=securityeagles,DC=local,
                             DC=DomainDnsZones,DC=securityeagles,DC=local...}
```

- Get-DomainSID retrieves the Security Identifier (SID) for the current domain.
- Acquiring this information is critical for identifying the most sensitive and privileged domain accounts within the environment.

```
PS C:\Users\m.dynamo\Downloads> Get-DomainSID -credential $Cred
S-1-5-21-204598522-1414839267-3477406029
```

- Get-DomainPolicyData retrieves the effective password and Kerberos policies currently enforced across the domain.

```
PS C:\Users\m.dynamo\Downloads> Get-DomainPolicyData -credential $Cred


Unicode        : @{Unicode=yes}
SystemAccess   : @{MinimumPasswordAge=1; MaximumPasswordAge=42; MinimumPasswordLength=7; PasswordComplexity=1; P
rdHistorySize=24; LockoutBadCount=0;
                 RequireLogonToChangePassword=0; ForceLogoffWhenHourExpire=0; ClearTextPassword=0; LSAAnonymousN
okup=0}
KerberosPolicy : @{MaxTicketAge=10; MaxRenewAge=7; MaxServiceAge=600; MaxClockSkew=5; TicketValidateClient=1}
RegistryValues : @{MACHINE\System\CurrentControlSet\Control\Lsa\NoLMHash=System.Object[]}
Version        : @{signature="$CHICAGO$"; Revision=1}
Path           : \\securityeagles.local\sysvol\securityeagles.local\Policies\{31B2F340-016D-11D2-945F-00C04FB984
ACHINE\Microsoft\Windows NT\SecEdit\GptTmpl.inf
GPOName        : {31B2F340-016D-11D2-945F-00C04FB984F9}
GPODisplayName : Default Domain Policy
```

- Key Reasons to Enumerate Policy Data:
  - Password Policy: Essential for determining if brute-force or password spraying attacks are viable (e.g., minimum password length, complexity requirements).
  - Kerberos Policy: Critical for planning Kerberoasting attacks (e.g., maximum ticket age and renewal limits).

- Invoke-ShareFinder is used to discover and enumerate network shares located throughout the domain.

```
PS C:\Users\m.dynamo\Downloads> Invoke-ShareFinder  -credential $Cred
WARNING: [Invoke-UserImpersonation] Executing LogonUser() with user: SECURITYEAGLES\m.dynamo

WARNING: [Invoke-RevertToSelf] Reverting token impersonation and closing LogonUser() token handle
Name           Type Remark              ComputerName
----           ---- ------              ------------
ADMIN$   2147483648 Remote Admin        SECURITY-EAGLES-DC.securityeagles.local
C$       2147483648 Default share       SECURITY-EAGLES-DC.securityeagles.local
IPC$     2147483651 Remote IPC          SECURITY-EAGLES-DC.securityeagles.local
IT                0                     SECURITY-EAGLES-DC.securityeagles.local
NETLOGON          0 Logon server share  SECURITY-EAGLES-DC.securityeagles.local
SYSVOL            0 Logon server share  SECURITY-EAGLES-DC.securityeagles.local
ADMIN$   2147483648 Remote Admin        EAGLES01.securityeagles.local
C$       2147483648 Default share       EAGLES01.securityeagles.local
IPC$     2147483651 Remote IPC          EAGLES01.securityeagles.local
Share             0                     EAGLES01.securityeagles.local
```

- The goal is to discover common share types like file servers, backup shares, or sensitive document storage which often contain valuable credentials or configuration data

2- Users & groups enumeration

- Get-DomainUser retrieves a complete list of all user accounts within the domain.

```
PS C:\Users\m.dynamo\Downloads> Get-DomainUser -credential $Cred


logoncount              : 18
badpasswordtime         : 03/11/2025 21:11:37
description             : Built-in account for administering the computer/domain
distinguishedname       : CN=Administrator,CN=Users,DC=securityeagles,DC=local
objectclass             : {top, person, organizationalPerson, user}
lastlogontimestamp      : 03/11/2025 15:58:17
name                    : Administrator
objectsid               : S-1-5-21-204598522-1414839267-3477406029-500
samaccountname          : Administrator
admincount              : 1
codepage                : 0
samaccounttype          : USER_OBJECT
accountexpires          : NEVER
countrycode             : 0
whenchanged             : 03/11/2025 15:58:17
instancetype            : 4
```

- The resulting list forms the initial dictionary for attacks like password spraying and credential guessing

- We can refine our query to view the attributes of a specific user by providing their identity, such as the websvc service account.

```
PS C:\Users\m.dynamo\Downloads> Get-DomainUser -Identity websvc -credential $Cred


logoncount              : 0
badpasswordtime         : 01/01/1601 00:00:00
distinguishedname       : CN=web Service,CN=Users,DC=securityeagles,DC=local
objectclass             : {top, person, organizationalPerson, user}
displayname             : web Service
userprincipalname       : websvc@securityeagles.local
name                    : web Service
objectsid               : S-1-5-21-204598522-1414839267-3477406029-1108
samaccountname          : websvc
codepage                : 0
samaccounttype          : USER_OBJECT
accountexpires          : NEVER
countrycode             : 0
whenchanged             : 03/11/2025 20:48:21
```

- Here we used an LDAP filter to only show built-in Accounts and after that we selected the name and description attributes to be the output for the console
- Guest and Administrator are the built-in Accounts

```
PS C:\Users\m.dynamo\Downloads> Get-DomainUser -LDAPFilter "Description=*built*" -credential $Cred | Select name,Description

name          description
----          -----------
Administrator Built-in account for administering the computer/domain
Guest         Built-in account for guest access to the computer/domain
```

- Get-LastLoggedOn retrieves crucial host reconnaissance data, specifically identifying the last user who successfully logged on to the target machine.

```
PS C:\Users\m.dynamo\Downloads> Get-LastLoggedOn -ComputerName EAGLES01

ComputerName LastLoggedOn
------------ ------------
EAGLES01     SECURITYEAGLES\m.dynamo
```

- Knowing the last logged-on user is highly valuable. If that user possesses high privileges (like a Domain Admin), their cached credentials (or hash) may still reside in memory (LSASS) or the registry , we will see these in later sections .

- Get-DomainGroup retrieves a list of all group objects within the domain. To simplify the output and focus on what matters, we pipe the results to select only the Name property

```
PS C:\Users\m.dynamo\Downloads> Get-DomainGroup  -credential $Cred | select name

name
----
Administrators
Users
Guests
Print Operators
Backup Operators
Replicator
Remote Desktop Users
Network Configuration Operators
Performance Monitor Users
Performance Log Users
Distributed COM Users
IIS_IUSRS
Cryptographic Operators
Event Log Readers
Certificate Service DCOM Access
RDS Remote Access Servers
RDS Endpoint Servers
RDS Management Servers
```

- This command is essential for reconnaissance, as groups define user permissions and access rights

- We can refine our enumeration by using filters to search for groups that include the keyword 'Admin' in their name, allowing us to quickly identify high-value targets.

```
PS C:\Users\m.dynamo\Downloads> Get-DomainGroup  -credential $Cred "*admin*"


grouptype               : CREATED_BY_SYSTEM, DOMAIN_LOCAL_SCOPE, SECURITY
admincount              : 1
iscriticalsystemobject  : True
samaccounttype          : ALIAS_OBJECT
samaccountname          : Administrators
whenchanged             : 03/11/2025 20:39:05
objectsid               : S-1-5-32-544
objectclass             : {top, group}
cn                      : Administrators
usnchanged              : 16454
systemflags             : -1946157056
```

- Searching for terms like 'Admin', 'Service', or 'SQL' is a rapid way to prioritize groups that likely hold elevated privileges

- Get-NetLocalGroup help us to enumerate the local groups on the local (or remote) machine

```
PS C:\Users\m.dynamo\Downloads> Get-NetLocalGroup -ComputerName EAGLES01

ComputerName GroupName                          Comment
------------ ---------                          -------
EAGLES01     Access Control Assistance Operators Members of this group can remot
EAGLES01     Administrators                     Administrators have complete a
EAGLES01     Backup Operators                   Backup Operators can override
EAGLES01     Cryptographic Operators            Members are authorized to perf
EAGLES01     Device Owners                      Members of this group can chan
EAGLES01     Distributed COM Users              Members are allowed to launch,
EAGLES01     Event Log Readers                  Members of this group can read
EAGLES01     Guests                             Guests have the same access as
EAGLES01     Hyper-V Administrators             Members of this group have com
EAGLES01     IIS_IUSRS                          Built-in group used by Interne
EAGLES01     Network Configuration Operators    Members in this group can have
EAGLES01     Performance Log Users              Members of this group may sche
EAGLES01     Performance Monitor Users          Members of this group can acce
EAGLES01     Power Users                        Power Users are included for b
EAGLES01     Remote Desktop Users               Members in this group are gran
EAGLES01     Remote Management Users            Members of this group can acce
EAGLES01     Replicator                         Supports file replication in a
EAGLES01     System Managed Accounts Group      Members of this group are mana
EAGLES01     Users                              Users are prevented from makin
```

- Enumerating local groups is vital during a Red Team operation, as membership in the local Administrators group is frequently the first step toward local privilege escalation on a compromised machine.

3- Computers enumeration

- Get-DomainComputer retrieves a list of all computer objects joined to the domain.
- We will pipe the output to select only the Name property for a simplified list.

```
PS C:\Users\m.dynamo\Downloads> Get-DomainComputer -credential $Cred  | select name

name
----
SECURITY-EAGLES
EAGLES01
DESKTOP-9ETJI5G
EAGLES02
```

- To filter the results, we will specify the OperatingSystem parameter to retrieve only computers running Windows Server 2022.

```
PS C:\Users\m.dynamo\Downloads> Get-DomainComputer -operatingsystem "*server 2022*"  -credential $Cred


pwdlastset                    : 03/11/2025 15:36:19
logoncount                    : 26
msds-generationid             : {168, 102, 35, 31...}
serverreferencebl             : CN=SECURITY-EAGLES,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configura
                                tion,DC=securityeagles,DC=local
badpasswordtime               : 01/01/1601 00:00:00
distinguishedname             : CN=SECURITY-EAGLES,OU=Domain Controllers,DC=securityeagles,DC=local
objectclass                   : {top, person, organizationalPerson, user...}
lastlogontimestamp            : 03/11/2025 15:36:26
name                          : SECURITY-EAGLES
objectsid                     : S-1-5-21-204598522-1414839267-3477406029-1000
samaccountname                : SECURITY-EAGLES$
localpolicyflags              : 0
codepage                      : 0
samaccounttype                : MACHINE_ACCOUNT
whenchanged                   : 03/11/2025 15:41:33
accountexpires                : NEVER
```

STAY TUNED FOR MORE

SECURITY EAGLES

www.securityeagles.com

FROM LEARNERS TO LEADERS